

Semana 2 — Objetivos de Aprendizado

Objetivos de Aprendizagem

Permissões, SUID & SGID

Quais são os três grupos de permissão baseados em usuário no Linux? Owner, group e others.

Para que são usados os comandos Linux chmod, sudo, su, chown e chgrp? chmod modifica os direitos de acesso a arquivos, sudo executa comandos com privilégios elevados, su altera a identidade do usuário atual, chown altera a propriedade do arquivo e chgrp altera o grupo associado.

Qual é a finalidade do setuid e setgid nas permissões de arquivo do Linux e como utilizá-los? setuid e setgid fazem com que um arquivo seja executado com as permissões de seu owner ou group, respectivamente, e são aplicados usando chmod u+s ou g+s.

Qual é a diferença entre os comandos chown e chgrp? chown é usado para alterar tanto a propriedade de usuário quanto de group de um arquivo, enquanto chgrp é restrito a alterar apenas a propriedade do group.

Quais são algumas boas práticas para gerenciar permissões de arquivo no Linux? As boas práticas incluem aplicar o princípio do menor privilégio, evitar permissões de escrita global em arquivos sensíveis e auditar regularmente os controles de acesso.

Como você pode auditar alterações de permissões de arquivo em seu sistema? Você pode auditar alterações de permissões de arquivo configurando regras do auditd para monitorar caminhos específicos ou analisando logs do sistema em busca de syscalls relevantes.

O que é Umask no Linux? Umask é uma máscara numérica que determina as permissões padrão de criação de arquivos, subtraindo bits especificados das permissões máximas permitidas pelo sistema.

MAC

O que é MAC no Linux? MAC (Mandatory Access Control) é um modelo de segurança no qual o sistema impõe políticas de acesso que os usuários não podem modificar, sobrepondo as permissões discricionárias tradicionais.

Como o SELinux aplica o MAC? O SELinux aplica o MAC anexando labels de segurança a processos e objetos e permitindo ou negando ações com base em regras de política configuráveis.

Quais são as diferenças entre SELinux e AppArmor? SELinux utiliza políticas baseadas em labels com aplicação de tipos refinada, enquanto o AppArmor usa perfis baseados em caminho que geralmente são mais simples de configurar e gerenciar.

Qual é a finalidade da política em sistemas MAC? Uma política define as regras que governam quais interações entre sujeitos e objetos são permitidas, servindo como fonte autoritativa para todas as decisões de acesso.

Como funcionam as labels no SELinux? As labels atribuem um contexto de segurança (usuário, papel, tipo e, opcionalmente, nível) a cada processo e objeto, e as regras de política referenciam essas labels para determinar as operações permitidas.

O que são Type Enforcement, Role-Based Access Control e Multi-Level Security no SELinux? Type Enforcement governa o acesso por tipos de processo e objeto, RBAC restringe quais papéis podem acessar quais tipos, e MLS adiciona níveis hierárquicos de sigilo para impedir o fluxo não autorizado de informações.

Como você pode verificar o status do SELinux em um sistema? Execute `sestatus` ou `getenforce` para verificar se o SELinux está habilitado e se está sendo executado no modo enforcing, permissive ou disabled.

Quais são os comandos comuns de gerenciamento do SELinux? Os comandos comuns incluem `sestatus`, `getenforce`, `setenforce`, `audit2allow`, `restorecon`, `chcon` e `semanage`.

Como você define contextos de arquivo no SELinux? Use `chcon` para alterações de contexto temporárias ou `semanage fcontext` com `restorecon` para modificações persistentes respaldadas por política.

O que é um perfil do AppArmor? Um perfil do AppArmor é um conjunto de regras que define quais arquivos, capacidades e acessos de rede um aplicativo confinado tem permissão de usar.

Como você recarrega perfis do AppArmor? Execute `aa-disable` ou `aa-enforce` seguido de `apparmor_parser -r <profile>` ou simplesmente `systemctl reload apparmor`.

Qual é o conceito de menor privilégio no MAC? Menor privilégio significa conceder apenas os direitos mínimos de acesso necessários para que um processo ou usuário execute sua função pretendida, reduzindo a superfície de ataque.

Como você soluciona problemas do SELinux? Verifique `/var/log/audit/audit.log` em busca de negações AVC, use `audit2why` e `audit2allow` para interpretá-las e alterne temporariamente para o modo permissive para isolar bloqueios relacionados ao SELinux.

Qual é a importância dos logs de auditoria em sistemas MAC? Os logs de auditoria registram cada negação de política e evento de acesso relevante, fornecendo visibilidade sobre operações bloqueadas e permitindo que administradores refinem as políticas.

Você pode explicar o conceito de capabilities na segurança do Linux? As capabilities dividem o privilégio monolítico de root em unidades distintas (por exemplo, `CAP_NET_RAW`, `CAP_SYS_ADMIN`), permitindo a atribuição refinada de permissões específicas de nível de kernel a processos sem conceder root completo.

Como você usa o semanage? Use `semanage` para modificar componentes de política do SELinux de forma persistente — por exemplo, `semanage fcontext -a -t httpd_sys_content_t "/web(/.*)?"` para adicionar uma regra de contexto de arquivo, seguido de `restorecon -R /web`.

Fundamentos do Windows

O que é o Windows e como ele difere de outros sistemas operacionais? Windows é um sistema operacional proprietário e centrado em GUI desenvolvido pela Microsoft que depende do kernel NT e de arquitetura de código fechado, distinguindo-se de sistemas de código aberto ou similares ao UNIX.

Qual é a arquitetura do Windows e como o modo kernel e o modo usuário interagem? A arquitetura separa o modo kernel privilegiado (responsável pelo hardware e funções centrais do SO) do modo usuário não privilegiado (que executa aplicações), com interações ocorrendo estritamente por meio de chamadas de sistema e troca de mensagens definidas para garantir estabilidade.

Como funciona o sistema de arquivos do Windows (NTFS) e o que são permissões e ACLs? O NTFS gerencia o armazenamento de dados usando registros da Master File Table e aplica

segurança por meio de Access Control Lists (ACLs) contendo Access Control Entries (ACEs) que definem regras específicas de permissão/negação para usuários e grupos.

O que é o Registro do Windows e qual papel ele desempenha na configuração do sistema? O Registro é um banco de dados hierárquico que armazena configurações de baixo nível para o SO e aplicações, servindo como repositório central de dados de configuração que substitui muitos arquivos de configuração legados baseados em texto.

Como o Windows gerencia usuários, grupos e controle de acesso? O Windows usa Security Identifiers (SIDs) para identificar exclusivamente usuários e grupos, aplicando tokens de acesso gerados no login para impor permissões em objetos protegidos por ACLs.

Como você navega pela interface do Windows e usa ferramentas administrativas integradas? A navegação é principalmente gráfica por meio do menu Iniciar e do Explorador de Arquivos, enquanto as tarefas administrativas são realizadas com ferramentas como Gerenciamento do Computador, Gerenciador de Tarefas, PowerShell e o aplicativo Configurações.

O que são processos e serviços do Windows e como você os monitora? Processos são instâncias ativas de programas em execução na memória, enquanto serviços são executados em segundo plano sem interação direta do usuário; ambos são monitorados e gerenciados por meio do Gerenciador de Tarefas ou do console Services.msc.

Como você usa o Prompt de Comando (cmd.exe) para administração básica do sistema? O Prompt de Comando executa comandos legados no estilo DOS como dir, ipconfig e netstat para realizar gerenciamento de arquivos, diagnósticos de rede e consultas ao sistema em uma interface baseada em texto.

O que são os Logs de Eventos do Windows e como você os lê e interpreta? Os Logs de Eventos registram cronologicamente eventos do sistema, segurança e aplicação, que os administradores analisam usando o Visualizador de Eventos para solucionar problemas, rastrear incidentes de segurança e monitorar a saúde do sistema.

Quais recursos de segurança integrados o Windows fornece, como UAC, Windows Defender e BitLocker? O Windows inclui User Account Control (UAC) para limitar o escalonamento de privilégios, Windows Defender para proteção antivírus em tempo real e BitLocker para criptografia total de disco de volumes de dados.

Como o Windows gerencia a configuração de rede e a conectividade? A configuração de rede é gerenciada por meio do Centro de Rede e Compartilhamento, cmdlets do PowerShell e configurações da pilha TCP/IP, utilizando DHCP, DNS e regras de firewall para estabelecer e proteger conexões.

Quais são as superfícies de ataque comuns baseadas em Windows e como podem ser mitigadas? Os vetores de ataque comuns incluem vulnerabilidades sem patches, credenciais fracas e portas RDP expostas, que são mitigadas por atualizações regulares, políticas de autenticação robusta, restrições de firewall e desativação de serviços desnecessários.

Ética e Metodologias em Forense Digital

O que é forense digital? Forense digital é o processo científico de identificar, preservar, analisar e apresentar evidências digitais de maneira legalmente admissível.

Por que a ética é importante na forense digital? A ética garante que os investigadores mantenham a confiança pública, protejam os direitos de privacidade individuais e garantam que as evidências sejam tratadas de forma imparcial, sem viés ou acesso não autorizado.

Quais são os problemas éticos comuns na forense digital? Os problemas comuns incluem violações de privacidade, expansão de escopo durante a coleta de dados, conflitos de interesse e a exposição acidental de informações sensíveis não relevantes.

Qual é o papel da integridade na análise forense? A integridade garante que as evidências permaneçam inalteradas desde o momento da apreensão até a apresentação em tribunal, tipicamente verificada por meio de hashing criptográfico para comprovar a autenticidade.

Como se mantém a objetividade em investigações digitais? A objetividade é mantida seguindo procedimentos padronizados, evitando noções preconcebidas sobre o resultado e documentando todas as descobertas independentemente de apoiarem ou não a hipótese inicial.

Quais são os princípios ACPO para forense computacional? Os princípios ACPO determinam que nenhuma ação deve alterar dados, uma trilha de auditoria deve ser criada, o investigador deve ser competente e as orientações das autoridades devem ser seguidas durante todo o processo.

Como você garante que as evidências sejam admissíveis em tribunal? As evidências são tornadas admissíveis aderindo estritamente aos padrões legais, mantendo uma cadeia de custódia documentada, usando ferramentas validadas e comprovando a autenticidade e integridade das evidências.

O que é cadeia de custódia e por que é crucial? A cadeia de custódia é a documentação cronológica de quem manuseou as evidências, quando e por quê; é crucial para evitar alegações de adulteração e estabelecer a confiabilidade das evidências em processos legais.

Quais são as etapas do processo forense digital? As etapas padrão são identificação, preservação, coleta, exame, análise e elaboração de relatório, frequentemente seguidas de apresentação em contextos legais ou administrativos.

Como se documentam as descobertas em um relatório forense? As descobertas são documentadas em um relatório claro e reproduzível que detalha a metodologia utilizada, as ferramentas empregadas, as ações tomadas passo a passo e os resultados específicos obtidos sem interpretação ou viés.

Quais são algumas metodologias forenses digitais padrão? As metodologias padrão incluem o framework NIST SP 800-86, o Método Científico aplicado a evidências digitais e protocolos específicos do setor como os do SANS ou IACIS.

Como se manuseia evidências digitais para preservar sua integridade? A integridade é preservada criando imagens forenses bit a bit, bloqueando a escrita na mídia original, calculando valores de hash antes e depois da análise e armazenando as evidências em ambientes seguros e controlados.

Quais são algumas ferramentas comuns usadas em forense digital? As ferramentas comuns incluem Autopsy (código aberto), EnCase, FTK (Forensic Toolkit), Wireshark para análise de rede e diversos write-blockers como hardware Tableau ou WiebeTech.

Quais organizações estabelecem padrões para práticas forenses digitais? As principais organizações incluem NIST (National Institute of Standards and Technology), ISO (International Organization for Standardization), SWGDE (Scientific Working Group on Digital Evidence) e ENFSI.

Como você se mantém atualizado com a evolução da tecnologia em forense? Os investigadores se mantêm atualizados por meio de educação continuada, participação em conferências (como DFRWS), obtenção de certificações (CFE, GCFA) e participação em comunidades profissionais e workshops de treinamento.

Quais são as implicações legais das investigações forenses digitais? As implicações legais envolvem conformidade com leis de busca e apreensão (como a Quarta Emenda nos EUA), adesão a regulamentos de proteção de dados (como o GDPR) e potencial responsabilidade por manuseio incorreto de evidências ou violação de privacidade.